

Runtime-Side Security Profile Generation for OCI Containers

Ivan Platonov

Innopolis University

Diploma Defense

- Containers share the host kernel; weak runtime confinement exposes kernel and host interfaces.
- Linux already has seccomp, AppArmor, and capabilities, but useful policies are hard to write and maintain.
- Sandboxed runtimes improve isolation but add overhead; cluster-side recorders require Kubernetes infrastructure.

RQ1

Can the runtime generate useful seccomp, AppArmor, and capability profiles without extra infrastructure?

RQ2

Does scan-then-enforce prevent command-injection exploitation and improve containment relative to stock `runc`?

Proposed Runtime Workflow

- ① Developer runs `runc run --security-scan` on representative traffic.
- ② The runtime relaxes confinement only in memory and records behaviour.
- ③ It emits `seccomp.json`, `apparmor.profile`, and capability evidence.
- ④ Finalisation narrows privileges from observed evidence.
- ⑤ Later runs enforce the generated profiles as ordinary OCI inputs.

Implementation Highlights

- Syscalls: `oci-seccomp-bpf-hook` generates a deny-by-default allow-list.
- Capabilities: `cgroup-wide capable-bpfcc` tracing observes child processes.
- AppArmor: complain-mode profile is converted to enforce mode after audit collection.
- Hooks are hidden subcommands of the runtime binary; the OCI bundle receives data artifacts only.

- Reproducible Flask laboratory with intentional command injection.
- Stock `runc`: reconnaissance, sensitive reads, reverse shell, mount probe, and persistence payloads succeed.
- Hardened scan-then-enforce: injected commands are blocked while legitimate ping and calendar upload remain functional.
- Controlled ablation shows defence in depth beyond the first denied `execve`.

After Thesis Submission: Additional Results

- Performance campaign: 50 measured repetitions after warm-up on CPU, memory, network, and Redis workloads.
- Enforcement overhead: below 1% on CPU, memory, and loopback network; about 5.5% on Redis.
- Security corpus: 22 reproducers across stock `runc`, hardened `raw`, hardened `enforced`, and `gVisor`.
- Hardened `enforced` configuration blocks all 17 applicable attack reproducers and all 15 kernel-boundary probes.

Security Comparison

Class	Stock runc	Enforced	gVisor
Syscall	5/5	5/5	5/5
Capability	3/4	4/4	3/4
Filesystem	0/3	3/3	1/3
Lateral	1/3	3/3	1/3
Misconfig	1/3	n/a	1/3

The misconfiguration row is an explicit limitation: profiles cannot repair `--privileged` or host namespace choices.

Conclusion and Remaining Work

- Runtime-side profiling raises the security floor for plain OCI deployments.
- It keeps near-native performance for common workloads and avoids cluster-side recorder infrastructure.
- Remaining work: merge file capabilities, extend application coverage, export SPO-compatible resources, and repeat benchmarks on KVM/bare metal.